1. Information Security Program Overview

BluePeak Systems is a fictional cloud software company. This policy manual defines minimum information-security and technology-use requirements for employees, contractors, and approved third parties.

Objectives

Protect the confidentiality, integrity, and availability of BluePeak information and systems.

Shared responsibility

Security is a shared responsibility. Users must follow technical controls and promptly report suspected incidents.

Exceptions

Exceptions require documented risk acceptance by the system owner and Information Security.

- Use company-approved systems for company work.
- Follow least-privilege principles.
- Report suspicious activity immediately.

Applies to: All employees unless otherwise stated.
Policy owner: Information Security
Review cycle: Annual

2. Data Classification

Information must be classified based on sensitivity and business impact.

Public

Information approved for public release, such as published marketing materials.

Internal

Routine business information intended for employees and approved partners.

Confidential

Sensitive business, customer, employee, security, or financial information.

Restricted

Highly sensitive information requiring the strongest controls, such as authentication secrets or regulated data.

Classification	Example
Public	Published product documentation
Internal	Internal operating procedures
Confidential	Customer contracts, employee records
Restricted	Passwords, private keys, regulated datasets

Applies to: All employees unless otherwise stated.
Policy owner: Information Security
Review cycle: Annual

3. Identity and Access Management

Access must be authorized, role-based, and reviewed periodically.

Unique identity

Users must use individually assigned accounts. Shared accounts require explicit approval.

Least privilege

Access should be limited to the minimum required for job responsibilities.

Access reviews

System owners review privileged access quarterly and standard access at least annually.

- Disable access promptly when no longer needed.
- Do not share credentials.
- Use role-based groups where practical.

Applies to: All employees unless otherwise stated.
Policy owner: Identity & Access Management
Review cycle: Annual

4. Passwords and Multi-Factor Authentication

Strong authentication reduces the likelihood of account compromise.

Password requirements

Passwords must meet system-defined complexity and length requirements. Reuse of corporate passwords on personal services is prohibited.

MFA

Multi-factor authentication is required for remote access, administrative access, and cloud applications where supported.

Password managers

Employees should use the company-approved password manager for storing work credentials.

- Never approve an unexpected MFA prompt.
- Report suspected credential theft immediately.
- Do not store passwords in documents or source code.

Applies to: All employees unless otherwise stated.
Policy owner: Identity & Access Management
Review cycle: Annual

5. Endpoint Security

Company-managed endpoints must use approved security controls and remain current with patches.

Device management

Corporate laptops and mobile devices must remain enrolled in endpoint management.

Patching

Critical security updates should be installed within the timeframe set by IT or Security.

Local administration

Local administrator rights are restricted and require business justification.

- Do not disable anti-malware or EDR agents.
- Lock screens when unattended.
- Lost or stolen devices must be reported immediately.

Applies to: All employees unless otherwise stated.
Policy owner: IT & Security
Review cycle: Annual

6. Acceptable Use of Company Technology

Company technology is primarily for authorized business purposes. Limited personal use is permitted if it is lawful, reasonable, and does not interfere with work.

Prohibited use

Users may not use company resources for illegal activity, harassment, malware, unauthorized cryptocurrency mining, or attempts to bypass security controls.

Monitoring

BluePeak may monitor corporate systems and networks in accordance with law and company policy.

Software installation

Only approved software may be installed on managed devices.

- Do not connect unauthorized storage devices.
- Do not disable logging or monitoring.
- Use approved collaboration tools for company content.

Applies to: All employees unless otherwise stated.
Policy owner: IT
Review cycle: Annual

7. Email, Messaging, and Phishing

Email and messaging are common attack channels. Users must exercise caution with links, attachments, and requests for sensitive information.

Phishing

Unexpected login prompts, urgent payment requests, and unusual attachments should be treated as suspicious.

Sensitive data

Restricted data must not be sent through unapproved email or messaging channels.

Reporting

Use the phishing-report button or contact Security Operations when a message appears suspicious.

- Verify payment or account-change requests through a second channel.
- Do not forward suspicious messages externally.
- Do not enter credentials after following an unexpected link.

Applies to: All employees unless otherwise stated.
Policy owner: Security Operations
Review cycle: Annual

8. Remote Work Security

Remote work must provide security protections comparable to office work.

Networks

Use trusted home networks or approved secure connectivity. Public Wi-Fi should be avoided for sensitive work unless protected by approved VPN or equivalent controls.

Physical privacy

Position screens to prevent unauthorized viewing and use headsets for confidential conversations.

Household access

Family members and visitors may not use company-managed devices.

- Keep devices under personal control while traveling.
- Store printed confidential documents securely.
- Use privacy screens where appropriate.

Applies to: All employees unless otherwise stated.
Policy owner: Information Security
Review cycle: Annual

9. Cloud Services and SaaS Usage

Only approved cloud services may store, process, or transmit company information.

Procurement

New SaaS tools require security, privacy, legal, and procurement review as applicable.

Data location

Teams should understand where confidential or restricted information is stored.

Access

SSO and MFA should be enabled where supported.

- Do not create shadow IT accounts for business data.
- Review third-party integrations before enabling them.
- Remove unused SaaS access promptly.

Applies to: All employees unless otherwise stated.
Policy owner: Cloud Governance
Review cycle: Annual

10. Encryption and Key Management

Sensitive information must be protected in transit and at rest using approved cryptographic controls.

Encryption in transit

Use TLS or other approved secure protocols for network transmission.

Encryption at rest

Confidential and restricted data should be encrypted using approved platform capabilities.

Key management

Encryption keys and secrets must be stored in approved key-management systems and rotated according to policy.

- Do not hard-code secrets in repositories.
- Limit key access to authorized services and users.
- Report exposed secrets immediately.

Applies to: All employees unless otherwise stated.
Policy owner: Security Architecture
Review cycle: Annual

11. Secure Software Development

Security requirements must be integrated into the software development lifecycle.

Code review

Production changes require peer review unless an approved emergency process applies.

Dependency management

Teams must monitor third-party dependencies for known vulnerabilities.

Secrets

Source repositories must not contain passwords, tokens, private keys, or other secrets.

- Use approved CI/CD pipelines.
- Run security scanning appropriate to the application.
- Document risk acceptance for unresolved high-severity issues.

Applies to: All employees unless otherwise stated.
Policy owner: Product Security
Review cycle: Annual

12. Vulnerability and Patch Management

Systems must be assessed for vulnerabilities and remediated according to severity and exposure.

Scanning

Internet-facing and critical internal systems are scanned regularly.

Remediation targets

Critical vulnerabilities should be addressed as rapidly as practical, generally within 7 days; high-severity issues generally within 30 days.

Exceptions

Temporary exceptions require risk acceptance and compensating controls.

Severity	Target Remediation
Critical	7 days
High	30 days
Medium	90 days
Low	As scheduled

Applies to: All employees unless otherwise stated.
Policy owner: Vulnerability Management
Review cycle: Annual

13. Logging and Monitoring

Security-relevant events should be logged to support detection, investigation, and compliance.

Coverage

Authentication, privileged activity, administrative changes, and critical system events should be logged.

Retention

Security logs are retained according to system risk and legal requirements.

Alerting

High-confidence indicators of compromise should generate alerts to Security Operations.

- Protect logs from unauthorized modification.
- Synchronize system time.
- Avoid logging secrets or full authentication tokens.

Applies to: All employees unless otherwise stated.
Policy owner: Security Operations
Review cycle: Annual

14. Security Incident Response

Security incidents require prompt containment, investigation, remediation, and communication.

What to report

Report suspected malware, phishing, lost devices, credential compromise, unauthorized access, data exposure, or unusual system behavior.

Initial response

Do not attempt extensive self-remediation if doing so could destroy evidence. Follow Security Operations instructions.

Communication

Only authorized personnel may communicate externally about security incidents.

- Report incidents immediately, even when uncertain.
- Preserve relevant evidence.
- Cooperate with incident responders.

Applies to: All employees unless otherwise stated.
Policy owner: Security Operations
Review cycle: Annual

15. Data Retention and Disposal

Information should be retained only as long as needed for business, legal, contractual, or regulatory purposes.

Retention schedules

Business owners must follow applicable retention schedules.

Legal hold

Information subject to legal hold must not be deleted until the hold is released.

Secure disposal

Storage media and records containing sensitive information must be securely destroyed or sanitized.

- Do not retain duplicate data without a business need.
- Use approved deletion processes.
- Coordinate disposal of physical media with IT.

Applies to: All employees unless otherwise stated.
Policy owner: Information Governance
Review cycle: Annual

16. Third-Party Security

Third parties that access company systems or data must be assessed and managed according to risk.

Due diligence

Security review is required before onboarding vendors that handle confidential or restricted information.

Contracts

Security and privacy obligations should be documented contractually.

Ongoing monitoring

High-risk vendors may be reassessed periodically.

- Limit vendor access to necessary systems.
- Disable access when contracts end.
- Escalate vendor incidents promptly.

Applies to: All employees unless otherwise stated.
Policy owner: Third-Party Risk Management
Review cycle: Annual

17. Backup, Recovery, and Business Continuity

Critical systems and data must be recoverable within business-defined objectives.

Backups

Critical data should be backed up using managed services or approved backup solutions.

Testing

Recovery procedures should be tested periodically.

Resilience

System owners should define recovery time objectives and recovery point objectives appropriate to business impact.

- Protect backups from unauthorized deletion.
- Maintain recovery documentation.
- Review continuity plans after major system changes.

Applies to: All employees unless otherwise stated.
Policy owner: Business Continuity
Review cycle: Annual

18. Privileged Access and Production Changes

Privileged access presents elevated risk and is subject to stronger controls.

Administrative accounts

Privileged users should use separate administrative identities where supported.

Approval

Production changes must follow change-management procedures.

Emergency access

Break-glass access must be tightly controlled, logged, and reviewed after use.

- Do not use admin accounts for routine email or browsing.
- Review privileged group membership quarterly.
- Log emergency changes and obtain retrospective approval.

Applies to: All employees unless otherwise stated.
Policy owner: Platform Engineering
Review cycle: Annual

19. Generative AI and External AI Services

Employees may use approved generative AI services for business purposes when they follow data-handling, security, and intellectual-property requirements.

Approved services

Only company-approved AI services may process company information.

Restricted inputs

Restricted data, authentication secrets, unreleased source code, or customer confidential data must not be entered into public AI services.

Human review

AI-generated content must be reviewed for accuracy, security, bias, and appropriateness before business use.

- Do not treat AI output as authoritative without validation.
- Respect copyright and licensing obligations.
- Report suspected data exposure through an AI service.

Applies to: All employees unless otherwise stated.
Policy owner: AI Governance
Review cycle: Annual

20. Enforcement, Exceptions, and Policy Contacts

Violations of security policy may result in access restrictions, corrective action, or other consequences consistent with company policy and law.

Exceptions

Policy exceptions must describe the business need, scope, duration, risk, and compensating controls.

Enforcement

Security may restrict or revoke access when necessary to protect systems or information.

Contacts

Security Operations handles incidents; IT handles device support; Privacy handles personal-data questions; Legal handles regulatory or contractual interpretation.

Contact	Purpose
Security Operations	Incidents, phishing, suspicious activity
IT Service Desk	Devices, software, account support
Privacy Office	Personal-data handling and privacy questions
Legal	Contractual and regulatory interpretation

Applies to: All employees unless otherwise stated.
Policy owner: Chief Information Security Office
Review cycle: Annual